

02_THREAT_MODEL: Aura-Guard v1.3

Version: 1.3 "Atom-Grade"

Scope: Security Boundaries, Mitigations, and Explicit Non-Goals

1. Introduction

Aura-Guard v1.3 operates as a deterministic security layer. Its security posture is based on the principles of **Immutability, Authenticity, and Verifiability**. This document outlines the threats addressed by the system and defines the operational boundaries for security auditors.

2. Protected Assets

- **Audit Log Integrity:** Ensuring that once a decision is recorded, it cannot be altered or removed without detection.
- **Policy Authenticity:** Ensuring only authorized, signed policies govern the AI decision-making process.
- **Decision Reproducibility:** Ensuring that for a given input, the audit outcome is always verifiable.

3. Threat Analysis & Mitigations

Threat Category	Description	v1.3 Mitigation Strategy
Bypass Attacks (Evasion)	User uses hidden Unicode characters or homographs to bypass regex filters.	NFC Normalization & Unicode Stripping in the normalizer.rs layer. All input is "cleaned" before evaluation.
Log Tampering	An intruder or rogue admin modifies the audit logs to hide a breach or violation.	Cryptographic Hash Chaining . Every log entry is linked to the previous one. A broken chain triggers a verification failure.
Policy Manipulation	Unauthorized modification of policy rules to permit restricted content.	Ed25519 Signatures . The engine will not load or execute a policy file without a valid cryptographic signature.
ReDoS (Regular Expression DoS)	Attacker provides inputs designed to crash the regex engine or consume CPU.	Regex Hardening . Policies are pre-validated for dangerous patterns; execution timeouts are enforced.

4. Operational Philosophy: Fail-Closed

In any scenario where system integrity is in doubt, Aura-Guard defaults to a **Fail-Closed** state:

- If a policy file's signature is invalid: **Service Refusal**.
- If the audit log filesystem is full or unwritable: **System Halt (Halt-on-Log-Failure)**.
- If a core integrity check fails: **Panic/Exit** to prevent unmonitored traffic.

5. Explicit Non-Goals & Out-of-Scope Threats

Defining what the system does *not* do is critical for accurate risk assessment:

- **Semantic Intent Detection:** Aura-Guard does not use probabilistic ML to "guess" user intent. It is a deterministic engine based on explicit rules.
- **Fact-Checking:** The system does not verify the truthfulness of AI responses.
- **Halucination Prevention:** Aura-Guard audits the *content* of the interaction but cannot detect if the underlying LLM is hallucinating unless it violates a specific policy rule.
- **Network-Level Attacks:** Protection against DDoS at the network layer or mTLS breaches must be handled by the infrastructure hosting Aura-Guard.

6. Attack Surface

The primary attack surface is the **v1/audit API endpoint**. In v1.3, this is secured via:

- API Key Authentication.
- mTLS (Optional but recommended for production).
- Strict JSON schema validation.

This threat model is reviewed periodically to align with evolving AI security standards (OWASP for LLMs, NIST AI RMF).